

[doc. web n. 9955372]
Provision of October 26, 2023
Register of Provisions
n. 496 of October 26, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Attorney
Guido Scorza, Member, and Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC, "General Data Protection Regulation" (hereinafter, "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the "Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Guarantor for the protection of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, doc. web n. 1098801;

REPORTING Prof. Pasquale Stanzione;

PREMISED

1. Introduction.

Following a specific report from the Trade Unions OO.SS. FILT-CGIL Milan and FILT-CGIL Lombardy (see notes of XX and XX on file), a presumed violation of the regulations concerning the protection of personal data was reported, regarding the dissemination of personal data of numerous employees of certain companies managing local public transport services in the territory of the Lombardy Region (hereinafter "Region") (companies Milano Serravalle – Milano, Tangenziali p.A., Autostrada Pedemontana Lombarda p.A. and Serravalle Engineering r.l.).

In particular, it was reported that in XX, following a contract signed on XX - entered into between the Region and FNM S.p.A. for the purchase, by the latter, of the shares of Milano Serravalle S.p.A. held by the Region - the sale was completed on XX - "several employees [of the aforementioned companies] discovered that by typing their name and surname into any search engine, a hyperlink to the draft contract between the Lombardy Region and FNM S.p.A. appeared, among whose attachments were lists of employees of the companies involved in the operation, including data related to the employment relationship, income received (divided by income type) and a list of all pending judicial proceedings with the workers", as well as some references to the health conditions of certain individuals.

The file containing the aforementioned contract and its attachments "was freely downloadable at the address: <http://areadocumentale.servizirl.it/atti/download/AAAAYBnbrd+mLfAGu+72pN0QYxN3M4aK32vCcmNvmk8hVXf3fjep0bQsNQC7UmdgDnC9xEgZ8zuE2iFMHjU8OyA+9y/77kJ+AfRKA8burSpa3>

whChTFoy/A==”, the domain “servizirl.it” being registered in the name of the Lombardy Region. “Only after the intervention of the union representatives was the file finally removed, after being freely accessible to anyone for over a year.”

According to the report, “in the context of the negotiations for the conclusion of the sale contract and the due diligence operations, the companies Milano Serravalle S.p.A., Autostrada Pedemontana S.p.A. and Serravalle Engineering communicated, pursuant to and for the purposes of Article 14 of Reg. 2016/679, to the Lombardy Region and FNM S.p.A. the names of the employees, divided by category under Article 2095 of the Civil Code, the tasks performed by each, the position held, the monthly salary, the gross annual salary, the allowances received, and the amount of the performance bonus received.” In particular, the published resolution was accompanied by “the list of all pending disputes with the workers, indicating for each the name of the employee, the competent authority, the reasons for the dispute, the hearing dates, and the value of the dispute.”

2. The investigative activity.

With note of XX, prot. n. XX, and subsequent integrations, the Region, in response to a request for information from the Guarantor (note prot. n. XX of XX), declared, in particular, that:

- “the [...] Region has proceeded to publish on the institutional portal of the Lombardy Region - Area publication of deliberative acts of the Regional Government Resolution No. XX of XX concerning the sale of the shareholdings held in Milano Serravalle – Milano Tangenziali S.p.A. and the related sale contract of the shareholdings, including the attachments. For this of a contract between legal entities. The complaints against the Region, therefore, cannot be directed at it as the data controller in its capacity as 'employer of the data subjects';

"Similarly, the allegation regarding the failure to make the data intelligible is unfounded, as the verification of the data contained in the documents and the compliance with the principles of minimization, correctness, and transparency did not fall to the Region, as it was not the 'employer' in contact with the workers, the data subjects, and it was not the data controller for the communication under Article 14 GDPR";

"The Lombardy Region did not process the data of the workers in its capacity as employer. Instead, it processed the data contained in the documents sent to it by the respective data controllers for the publications it was required to make, in its capacity as a public entity, part of a contract between legal entities."

contractor of a transaction between legal entities.

Such processing was lawful, in compliance with Article 6 of the GDPR, finding legal basis and purpose in the obligations imposed by Article 22 letter d-bis of Legislative Decree 33/2013. 'Obligations to publish data relating to public entities under supervision, and to private law entities under public control, as well as to shareholdings in private law companies';

“as for the methods of processing and the general principles referred to in Article 5 of the GDPR, it is necessary to clarify that since it concerns a transaction between legal entities and the obligation to publish pertains - as clearly inferred from the regulatory text - to data of legal entities, which are thus excluded from the scope of application of the GDPR and the Privacy Code, the Region cannot be blamed for not having applied the same caution and attention to the processing of data imposed by the regulations, which it usually applies for operations that, immediately, involve the processing of personal data of natural persons”;

“in this condition, the conduct of the Region is certainly subject to criticism for not having paid, in the perspective of full accountability, additional attention to the verification of the data contained in the attachments sent to it - however not drafted by it - favoring the full compliance with its advertising obligations and limiting itself to publishing the documents in their entirety as transmitted by the respective holders, employers, companies involved in the transaction, in order to avoid the sanction of ineffectiveness linked to the failure or incomplete publication of data relating to the entities and the consequent prohibition on the disbursement of funds. This is evidently a caution that will be implemented in the future but attributable to a level of responsibility that cannot go beyond mere culpa in vigilando, and, in any case, slight”;

“the Region, in order to avoid the recurrence of even merely accidental events even in anomalous situations, has already taken steps to prepare a further in-depth analysis and impact assessment of the publication processing on the institutional portal”;

“the interested parties are not employees of the Region. The data were neither collected nor drafted by the Region, which merely published the documents, as transmitted by the respective holders, employers, companies involved in the transaction. As recalled in previous notes, the publication of the Regional Council Resolution also took place during a period in which the Lombardy Region, more than what was happening in other parts of Italy, was in full pandemic emergency. A period in which the Region had to face immediately and in a situation of difficulty, the numerous requests arising from health, social, and economic needs. The difficult moment described did not facilitate a meticulous analysis of the act at the time of publication, despite the presence of suitable procedures, always followed in strict compliance with privacy regulations. This was also determined by the innocent belief of having received documentation already adequate to comply with the principles of necessity, proportionality, and relevance”;

“as accidental as the contested event may have been, the Region has already committed itself, and reiterates in this context its commitment, going forward, to pay greater attention also to what is transmitted to it and also in transactions or relationships involving mere legal entities”;

“a charge against the Region, in this case, cannot be made as it is the employer of the interested parties, nor can it arise from the mere fact that they are ‘employees of the companies that manage the public transport service in the Lombardy territory’ as a form of ‘territorial’ responsibility, nor as objective liability for the fact that the domain is registered in its name, but in terms of a slight fault arising from not having paid greater attention to the analysis of the documents sent to it, before proceeding, in fulfilling its transparency obligations, to the publication of the resolution, to which the attachments were included, failing due to an excess of ‘trust’ in the correctness of the documentation transmitted to it”;

“the responsibility of the Region in the dissemination of the ‘controversial’ data is configurably a mere concurrence of slight fault, in vigilando, in a sporadic episode that occurred in the absolutely exceptional context of a transaction between legal entities, thus not directly affected by privacy regulations, and in historical contingencies that saw the Region in full pandemic emergency, with reduced staff and grappling with the first experiences of remote work, with the consequent operational difficulties”;

“Lombardy Region has taken the appropriate steps to remove the data as soon as requested by the interested parties, showing maximum cooperation and availability”;

“Lombardy Region has a structured organizational framework for the protection of personal data, its own DPO, a constantly updated and implemented Register of processing activities, also based on policy by design and policy by default analyses of processing and DPIAs conducted for high-risk processing”;

“operational instructions on the correct processing of personal data are provided to newly hired employees [...]; System Administrators are designated, ongoing training is carried out to keep the Structure attentive to privacy regulations and new operational needs. Policies on data protection are drafted, updated information for processing, a register of requests, and a dedicated page for staff with infographics and templates to use”;

the EDMA platform, used for the drafting and publication of resolutions in the Region, has been

Subject of further detailed analysis, a working group has been created for the definition of the correct rules of data retention and removal of data, documents, and information subject to mandatory publication.

“these are not data related to criminal convictions and offenses. The data complained about regarding dissemination are all related to the employment relationship and transmitted to the Region by the respective employers. It also appears that the relevant data under Article 9 GDPR are isolated cases. The documents subject to publication were sent to the Lombardy Region, not drafted by it, nor did the Region collect said data as the data controller, but it was, in turn, a recipient through communication from the controller.”

The Region did not request to be heard by the Guarantor pursuant to Article 166, paragraph 6, of the

Code.

****3. Outcome of the investigative activity.****

****3.1 The regulatory framework****

The regulation on the protection of personal data provides that the processing of personal data by public entities can only be carried out if necessary “to comply with a legal obligation to which the data controller is subject” or “for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller” (Article 6, paragraph 1, letters c) and e) of the Regulation).

Such processing must, in any case, find its basis in Union or Member State law, which must pursue a public interest objective and be proportionate to the pursuit of the same. The purpose of the processing must be necessary for the execution of a task carried out in the public interest or connected to the exercise of public powers vested in the data controller (cf. Article 6, paragraph 3, of the Regulation and Article 2-ter of the Code).

With regard to special categories of personal data, including those related to health (for which a general prohibition on processing is provided, except in the cases indicated in Article 9, paragraph 2 of the Regulation and, in any case, a regime of greater guarantee compared to other types of data, particularly due to Article 9, paragraph 4, as well as Article 2-septies of the Code), processing is permitted where “necessary for reasons of substantial public interest based on Union or Member State law, which must be proportionate to the pursued purpose, respect the essence of the right to data protection, and provide for appropriate and specific measures to safeguard the fundamental rights and interests of the data subject” (Article 9, paragraph 2, letter g), of the Regulation).

The national legislator has defined “relevant” the public interest for processing “carried out by entities performing tasks of public interest or connected to the exercise of public powers” in the areas indicated, albeit not exhaustively, by Article 2-sexies of the Code, establishing that the related processing “is permitted when provided for by European Union law or, in the domestic legal system, by provisions of law or, in cases provided for by law, by regulations that specify the types of data that may be processed, the operations that can be carried out, and the reason for substantial public interest, as well as the appropriate and specific measures to safeguard the fundamental rights and interests of the data subject.”

In any case, health-related data, i.e., those “related to the physical or mental health of a natural person, including the provision of health care services, which reveal information concerning their health status” (Article 4, paragraph 1, no. 15 of the Regulation), due to the greater guarantees recognized by the Regulation and the Code, given the particular sensitivity of this category of data, “cannot be disseminated” (Article 2-septies, paragraph 8, of the Code).

The data controller is, in any case, required to comply with the general principles regarding the protection of personal data (Article 5 of the Regulation).

****3.2 The online dissemination of personal data of employees of companies managing local public transport services in the territory of the Lombardy Region****

As evidenced by the documents, as well as the findings made based on the elements acquired, following the investigative activity and the subsequent assessments of the Office, it has been established that the Region published, from XX to XX on its institutional website, the “Regional Council Resolution no. XX of XX concerning the sale of the shareholdings held in Milano Serravalle – Milano Tangenziali S.p.A. and the related contract for the sale of the shares, including the attachments” and that the file containing the aforementioned contract and the related attachments “was freely downloadable at the address: <http://areadocumentale.servizirl.it/atti/download/AAAAYBnbrd+mLfAGu+72pN0QYxN3M4aK32vCcmNvmk8hVXf3jep0bQsNQC7UmdgDnC9xEGz8zuE2iFMHjU8OyA+9y/77kJ+AfrKA8burSpa3whChTFoy/A==>.”

Although, as stated by the Region, such data “were published not in the context of the employment

relationship and the processing of employee data by the employer,” the reference to the transparency obligations under Article 22 of Legislative Decree March 14, 2013, no. 33, which, in the opinion of the Region, would have justified the dissemination of personal data of employees, although not employees of the Region, contained, in particular, in the attachments to the draft contract (attached to resolution XX of XX), does not appear relevant. It is represented, in fact, that such provisions do not provide for the publication of data related to

****Employment Report of Employees of the Companies Involved****

including, among others, the income received by each worker, broken down by income category, nor the list of judicial proceedings against individual workers.

In particular, paragraph 1 letter d-bis) of Article 22 of the aforementioned decree provides, among the obligations for the publication of data relating to public entities under supervision and private law entities under public control, exclusively for the publication of “provisions concerning the establishment of public participation companies, acquisition of shares in already established companies, management of public shareholdings, disposal of shareholdings,” without any specific and direct obligation to publish “identifying data, classification, qualification, date of hiring, and length of service, as well as the total company cost in terms of gross annual salary and other remuneration elements” related to individual workers (see point 9.18.1 of the draft contract attached to the response note of XX) nor of “pending judicial proceedings with workers” (see attachment 9.18.12 to the draft contract).

The legislation, in fact, does not authorize the publication of personal data, but exclusively provides for a specific regime of transparency regarding “provisions concerning the establishment of public participation companies, acquisition of shares in already established companies, management of public shareholdings, disposal of shareholdings, listing of public control companies in regulated markets, and periodic rationalization of public shareholdings” by public administrations, to be updated annually.

In this regard, in the specific case, the Resolution of the Regional Council No. XX of XX contained, in the annex, the list of approximately 732 employees of the aforementioned companies and in particular information primarily related to “litigations, remuneration, length of service, qualification, and generally career aspects” of the workers.

From the documentation on file, it also emerges that, in the case of one employee, information related to health was also reported concerning the request for compensation for damages caused to the worker's health due to harassing behavior by the employer (see paragraphs 9.18.12 and 9.19 of the aforementioned resolution).

Reiterating that the personal data protection system requires a suitable legal basis for any processing operation (Article 4, point 2 of the Regulation), including dissemination (Article 2-ter, paragraph 4, letter b) of the Code), it is noted that the Guarantor has long provided guidance regarding the prerequisites (and the occurrence of these, the specific modalities) for the lawful publication, including online, of acts and documents containing personal data (see provision of May 15, 2014 No. 243 “Guidelines on the processing of personal data, including in administrative acts and documents, carried out for the purposes of publicity and transparency on the web by public entities and other obligated entities” web doc No. 3134436).

In this regard, it should be noted - given, in any case, the prohibition on the dissemination of health-related data - that the Guarantor has clarified on several occasions that even the possible presence of a specific publicity regime (a circumstance that does not occur in this case) cannot entail any automaticity regarding the online dissemination of personal data and information, nor a derogation from the principles regarding personal data protection (see cited Guidelines). This is also confirmed by the personal data protection system contained in the Regulation, according to which the data controller must implement “appropriate technical and organizational measures to ensure that, by default, only personal data necessary for each specific purpose of the processing are processed” and must be “able to demonstrate” - in light of the principle of “accountability” - that they have done so (Articles 5, paragraph 2; 24 and 25, paragraph 2, Regulation).

In this context, before proceeding with the publication of the resolution and the related annexes, the Region should have been aware of the presence of personal data relating to numerous workers and, consequently, should have verified the existence of a legal or regulatory provision that legitimized such publication, in compliance with the principle of lawfulness (see Article 5 of the Regulation).

Also considering that the document subject to publication also contained a reference to a litigation concerning compensation for damages caused to the worker's health due to harassing behavior by the employer, it must be deemed that the dissemination also concerned data related to health, namely the data "related to the physical or mental health of a natural person, including the provision of health care services, which reveal information concerning their health status" (Article 4, paragraph 1, No. 15, of the Regulation; see also recital 35 of the same).

This category of data also includes the mere reference to "any information from which one could infer, even indirectly, the state of illness or the existence of pathologies of the subjects concerned" (see cited Guidelines) as in this case.

Therefore, such data, although relating to a single worker, must be processed in compliance with the stricter regime applicable to health-related data which, as mentioned, cannot be disseminated (Article 2-septies, paragraph 8 of the Code).

This principle has been reiterated in numerous decisions of the Guarantor concerning individual cases (see among the

tanti, provision no. 68 of February 25, 2021, web doc no. 9567429; no. 255 of June 24, 2021, web doc no. 9688099; no. 404 of December 1, 2022, web doc no. 9842783; no. 405 of December 1, 2022, web doc no. 9844727; no. 420 of December 15, 2022, web doc no. 9853429; no. 3 of January 11, 2023, web doc no. 9857610).

Although the incident that led to this investigation occurred "during a period in which the Lombardy Region, more than what was happening in other parts of Italy, was in full pandemic emergency. A period in which the Region had to promptly address, in a situation of difficulty, the numerous requests arising from health, social, and economic needs," and although it immediately took action to ensure the definitive removal of the aforementioned personal data from the website upon learning of the news, it must nevertheless be concluded, for the reasons stated above, that the personal data of hundreds of workers (approximately 730), in one case even related to health, were published for an extended period - from XX to XX - on the institutional website of the Region, and freely accessible online, in the absence of a legal basis and in violation of the general prohibition on disseminating health-related data in violation of Articles 5, 6 par. 1 lett. c) and e) and 9 of the Regulation and Articles 2-ter and 2-septies, paragraph 8, of the Code.

However, the initiatives taken by the Region, also involving the Data Protection Officer, through the creation of "a working group to define the correct rules for data retention and removal of data, documents, and information subject to mandatory publication," are acknowledged favorably.

4. Conclusions.

In light of the evaluations mentioned above, it is noted that the statements made by the data controller during the investigation - the truthfulness of which may be subject to accountability under Article 168 of the Code - while deserving of consideration, do not allow for overcoming the objections notified by the Office with the initiation of the procedure and are insufficient to allow for the archiving of the present procedure, as none of the cases provided for by Article 11 of the Garante Regulation no. 1/2019 apply.

Therefore, the preliminary assessments of the Office are confirmed, and the illegality of the processing of personal data carried out by the Region is noted, given that the personal data of numerous workers (approximately 730), including data related to the health of one worker, were published from XX to XX on the institutional website of the Region, and freely accessible online, in the absence of a legal basis and in violation of the general prohibition on disseminating health-related data, in violation of Articles 5, 6 par. 1 lett. c) and e) and 9 of the Regulation and Articles 2-ter and 2-septies, paragraph 8, of the

Code.

The violation of the aforementioned provisions makes the administrative sanction provided for by Article 83, paragraph 5, of the Regulation applicable, pursuant to Articles 58, paragraph 2, lett. i), and 83, paragraph 3, of the same Regulation, as also referred to by Article 166, paragraph 2, of the Code.

In this context, considering that the conduct has exhausted its effects, given that the aforementioned data has been removed from the institutional website of the Region and from the network, the conditions for the adoption of further corrective measures under Article 58, paragraph 2, of the Regulation do not exist.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, lett. i) and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The Garante, pursuant to Articles 58, paragraph 2, lett. i) and 83 of the Regulation as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures [provided for in this paragraph], or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the College [of the Garante] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Garante's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Garante Regulation no. 1/2019).

In this regard, considering Article 83, paragraph 3, of the Regulation, in this case, the violation of the cited provisions is subject to the application of the administrative pecuniary sanction provided for by Article 83, paragraph 5, of the Regulation.

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into due account the elements provided for by Article 83, paragraph 2, of the Regulation.

In relation to the aforementioned elements, the particular sensitivity of the personal data subject to online dissemination concerning the management of the employment relationship and ongoing disputes of numerous interested parties has been considered, as well as, with regard to one worker, also data related to health. The dissemination also occurred over an extended period (from XX to XX). It was also considered that the failure to comply with the indications that the Garante has long provided to all public entities with the aforementioned Guidelines and in numerous provisions on individual concrete cases adopted over the years by the Garante.

On the other hand, it was taken into account that the Region, upon becoming aware of the publication even before the initiation of the investigation by the Garante, took all necessary actions. necessary to remove the personal data in question from its institutional website and from the network. It was also taken into account that the violation began during a particularly delicate phase (XX) in which the Region was engaged in addressing the specific needs arising from the state of emergency. Furthermore, the initiatives undertaken by the Region were evaluated, including the establishment of "a working group for the definition of the correct rules for data retention and removal of data, documents, and information subject to mandatory publication." There are also previous measures pursuant to Article 58, paragraph 2, against the Region, regarding relevant violations.

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the administrative fine at €20,000 (twenty thousand) for the violation of Articles 5, 6, paragraph 1, letters c) and e), and 9 of the Regulation and Articles 2-ter and 2-septies, paragraph 8, of the Code, as an administrative pecuniary sanction considered, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

Considering that the personal data subject to online dissemination concerned the personal data of numerous workers, including data related to health, it is also deemed necessary to apply the accessory sanction of publication of this measure on the website of the Authority, as provided for by

Article 166, paragraph 7 of the Code and Article 16 of the Regulation of the Authority No. 1/2019.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

declares, pursuant to Article 57, paragraph 1, letter f), of the Regulation, the unlawfulness of the processing carried out by the Lombardy Region for violation of Articles 5, 6, paragraph 1, letters c) and e), and 9 of the Regulation and Articles 2-ter and 2-septies, paragraph 8, of the Code, as stated in the reasoning;

ORDERS

the Lombardy Region, represented by its legal representative pro tempore, with registered office at Piazza Città di Lombardia, 1 - 20124 Milan (MI), Tax Code 80050050154, to pay the sum of €20,000 (twenty thousand) as an administrative pecuniary sanction for the violations indicated in the reasoning.

It is stated that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

COMMANDS

the aforementioned Region, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €20,000 (twenty thousand) according to the methods indicated in the annex, within 30 days from the notification of this measure, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the publication of this measure on the website of the Authority, considering that the conditions referred to in Article 17 of the Regulation of the Authority No. 1/2019 are met.

Pursuant to Articles 78 of the Regulation, 152 of the Code, and 10 of Legislative Decree No. 150/2011, it is possible to appeal this measure before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the measure itself or within sixty days if the appellant resides abroad.

Rome, October 26, 2023

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Stanzione

THE SECRETARY GENERAL

Mattei